



Desarrollo Web Profesional

José Miguel Carrera Pacheco



Alejandro Contreras Martinez

Emmanuel Castro Salvador

Carlos Eduardo Hernandez Camacho

Danna Paola Tobón Mosqueda

Manelic Alitzel Reyes Torres

8.-A

Investigación: Middleware, Protección de

Rutas y Control de Acceso en Backend

05/04/2026

Introducción

En el desarrollo de aplicaciones modernas, especialmente en entornos web, la seguridad es un aspecto fundamental que debe ser considerado desde la arquitectura del sistema. Uno de los componentes clave en la protección de aplicaciones es el uso de middleware, el cual permite interceptar y controlar las solicitudes antes de que lleguen a los recursos principales del sistema.

El uso adecuado de middleware, junto con estrategias de protección de rutas y validación de roles, permite garantizar que solo los usuarios autorizados puedan acceder a ciertas funcionalidades. Esto ayuda a prevenir vulnerabilidades, proteger la información y mantener la integridad del sistema.

¿Qué es un middleware?

Un middleware es una función o conjunto de funciones que se ejecutan entre la solicitud del cliente (request) y la respuesta del servidor (response).

Su función principal es interceptar, procesar o modificar las peticiones antes de que lleguen al controlador principal.

Características principales:

- Se ejecuta antes o después de una acción
- Puede permitir o bloquear una solicitud
- Se utiliza para validar, autenticar o registrar información

Ejemplo de uso:

- Validar si un usuario está autenticado
- Verificar permisos
- Registrar actividad (logs)
- Manejar errores

¿Cómo se protegen rutas en backend?

Las rutas en backend deben protegerse para evitar accesos no autorizados a recursos sensibles.

1. Autenticación

Antes de permitir el acceso, se debe verificar la identidad del usuario.

Métodos comunes:

- Tokens (JWT)
- Sesiones
- OAuth

2. Uso de middleware de seguridad

El middleware se utiliza para:

- Validar tokens
- Verificar sesiones activas
- Controlar permisos

3. Control de acceso

Se debe definir qué usuarios pueden acceder a cada ruta.

Ejemplo:

- /perfil → usuario autenticado
- /admin → solo administradores

4. Validación de datos

Se deben validar los datos que entran al sistema para evitar ataques como:

- SQL Injection
- XSS

5. Uso de HTTPS

Todas las comunicaciones deben estar cifradas para evitar interceptación de datos.

¿Qué errores de seguridad son comunes?

Un mal diseño del backend puede generar múltiples vulnerabilidades.

1. Falta de autenticación

Permitir acceso a rutas sin verificar identidad.

2. Validación insuficiente

No validar datos de entrada puede permitir:

- Inyección SQL
- Cross Site Scripting (XSS)

3. Exposición de información sensible

Mostrar errores detallados puede revelar:

- Estructura del sistema
- Consultas internas

4. Tokens inseguros

- Tokens sin expiración
- Tokens reutilizables
- Tokens almacenados incorrectamente

5. Falta de control de roles

Permitir que cualquier usuario acceda a funciones administrativas.

6. Mala gestión de sesiones

- Sesiones que no expiran
- Cookies sin protección

7. No usar HTTPS

Permite ataques de tipo "Man in the Middle".

¿Cómo se valida acceso por rol?

El control de acceso basado en roles (RBAC: Role-Based Access Control) es uno de los métodos más utilizados para restringir acceso en sistemas.

¿Qué es un rol?

Un rol define el nivel de acceso de un usuario dentro del sistema.

Ejemplo:

- Usuario
- Moderador
- Administrador

¿Qué son los permisos?

Son las acciones que un usuario puede realizar.

Ejemplo:

- Leer datos
- Editar información
- Eliminar registros

Importancia del middleware en la seguridad

El middleware permite centralizar la seguridad del sistema, evitando repetir código y asegurando que todas las rutas estén protegidas de manera consistente.

Gracias al middleware se pueden implementar políticas de seguridad de forma eficiente, como autenticación, autorización y validación de datos.

Conclusión

El uso de middleware en el backend es fundamental para garantizar la seguridad de una aplicación web. A través de este mecanismo, es posible proteger rutas, validar usuarios y controlar el acceso a los recursos del sistema.

Además, implementar correctamente la autenticación, autorización y control de roles permite prevenir ataques y asegurar que cada usuario tenga acceso únicamente a las funcionalidades que le corresponden.

Un diseño adecuado del backend, basado en buenas prácticas de seguridad, no solo protege la información, sino que también mejora la confiabilidad y calidad del sistema.

Referencias (APA 7)

Fielding, R. T., & Reschke, J. (2014). Hypertext Transfer Protocol (HTTP/1.1): Authentication. Internet Engineering Task Force.

<https://datatracker.ietf.org/doc/html/rfc7235>

OWASP Foundation. (2021). OWASP Top 10: The Ten Most Critical Web Application Security Risks.

<https://owasp.org/www-project-top-ten/>

OWASP Foundation. (2023). Authentication Cheat Sheet.

https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

OWASP Foundation. (2023). Access Control Cheat Sheet.

https://cheatsheetseries.owasp.org/cheatsheets/Access_Control_Cheat_Sheet.html

Richardson, L., & Ruby, S. (2007). RESTful web services. O'Reilly Media.

Tilkov, S., & Vinoski, S. (2010). Node.js: Using JavaScript to build high-performance network programs. IEEE Internet Computing, 14(6), 80–83.

Stallings, W., & Brown, L. (2018). Computer security: Principles and practice (4th ed.). Pearson.

NIST. (2020). Digital identity guidelines (SP 800-63-3). National Institute of Standards and Technology.

<https://pages.nist.gov/800-63-3/>